

SafeHR– Secure Human Resource Management System

Contents

1.0	Introduction.....	3
2.0	Project Overview	4
2.1	SafeHR systems key features:.....	4
3.0	Functional and Non- Functional Requirements	5
3.1	Functional Requirements	5
3.2	Non-Functional Requirements	5
4.0	Security Requirements Analysis	5
4.1	Access Control:.....	5
4.2	Authentication and Session Management:.....	6
4.3	Data Protection:	6
4.4	Monitoring and Logging:.....	7
4.5	Input and Error Handling:.....	8
5.0	Use Case Diagram.....	9
6.0	Threat Modelling Threat Modelling	9
6.1	Identifying Assets:	9
6.2	Identifying Threats.....	10
7.0	Architecture Design	13
8.0	Secure Architecture Design	15
9.0	Security Control Design.....	16
9.1	RBAC (Role-Based Access Control).....	19
10.0	Authentication and QR Code 2FA	19
11.0	Evaluation of Architecture.....	20
11.1	Strengths	20
11.2	Weaknesses	21
12.0	Documentation and Justification.....	22
12.1	Secure-by-Design Strategy	22
12.2	Security Requirements	22
12.3	Threat Modeling.....	22

12.4	Layers of Architecture	23
12.5	Matrix-based RBAC	23
12.6	Matrix of Security Controls	23
12.7	Monitoring & Logging.....	23
12.8	Evaluation & Weaknesses.....	23
12.9	Compliance & Rationale.....	24
13.0	Conclusion	24
14.0	References.....	25

1.0 Introduction

In these days, organizations can no longer afford to ignore their own security in an era where the rate of insider threats, data breaches, and cyberattacks are increasing excessively. Human resource management systems are very crucial to protect, as they are among the most data-sensitive digital infrastructure since these systems have an extensive collection of personal and professional data which includes employee identities, salaries, addresses, attendance, contracts, and even medical records. Therefore, this means any cybersecurity criminals see these systems to be an attractive target to exploit weak points in their security architecture. That's why there's a growing urgent need for securing HR systems as the relevance of using cloud-based platforms, digital workflows, and remote work increases as well.

In direct response to these risks, the SafeHR project was developed as it's a web-based HR management platform that was designed to help small and medium sized enterprises to go beyond standard HR capabilities by integrating security at every layer. This system was developed with a secure-by-design methodology, which involves threat mitigation techniques, encryption methods, access controls, and security controls from the earliest stages of development.

Throughout this report, SafeHR sets as an example for how modern HR platforms can be designed to be both protective and functional by outlining SafeHR functional and non-functional requirements, security objectives, architectural design, threat modeling and the reasons behind every security control.

2.0 Project Overview

The SafeHR project is a secure, web-based human resource management system that's aims to provide essential HR features and functionalities in a system that puts security, scalability, and usability first. By utilizing a Secure-by-Design method in difference of other traditional HR systems, proactive security controls are incorporated into development of every feature and component ensuring protection against typical and common attacks such as injection session hijacking, and unauthorized data.

2.1 SafeHR systems key features:

- Employee Profile Management: creating, updating and maintaining personal employee records.
- Attendance Tracking: keep track of when clock-in and clock-out data and integrate biometric scanners.
- Leave and Vacation Management: submit, approve, and monitor leave requests with real-time notifications.
- Secure File Storage: upload and save sensitive documents, such as reports and contracts, with validation and malware checks.
- Role-Base Access Control (RBAC): assign and enforce permissions according to user roles, such as admin, HR, and employee.

Other security features are included such as data encryption, activity logging, CSRF protection, and multi-factor authentication (MFA) with QR codes. Through complying with NIST guidelines, OWASP Top 10, and ISO/IEC 27001 standards, SafeHR guarantees data availability, confidentiality, and integrity throughout its infrastructure.

3.0 Functional and Non- Functional Requirements

3.1 Functional Requirements

The system must allow employees to submit new leave or vacation requests through their user accounts.

Employees must be able to view a list of all their previously submitted leave and vacation requests.

Admin and HR personnel must have the ability to add, edit, and delete employee records through the system.

Admin and HR personnel must be able to approve or reject leave and vacation requests submitted by employees.

The system must send real-time notifications (via email or in-app alerts) to employees regarding the status of their leave or vacation requests.

3.2 Non-Functional Requirements

The system must be protected by a Web Application Firewall (WAF) to detect and block malicious HTTP traffic.

It must prevent data leaks and unauthorized access to sensitive data.

Role-Based Access Control (RBAC) must be enforced throughout the system to prevent unauthorized tampering with data.

Under normal operating conditions, the system must respond to user actions within 2 seconds.

In the event of failure, the system must support automatic recovery mechanisms to minimize service interruption and maintain availability.

4.0 Security Requirements Analysis

4.1 Access Control:

- Employee Data Confidentiality:

Description: Employee-related personal data are private and may be viewed only by those granted access.

Rationale: Prevents leakage of data and apprehends the law, such as the GDPR.

Priority: High

Reference: ISO27001:2013 – A.9 Access Control

- Role-Based Access Control (RBAC):

Description: Access to application features and data must be limited by user roles (e.g., Admin, HR, Employee).

Rationale: To restrict exposure of sensitive data on a need-to-know basis.

Priority: High

Related Standards: NIST SP 800-53 AC-5

4.2 Authentication and Session Management:

- User Authentication:

Description: Every selected user should be required to authenticate with a unique username/password and the system must support MFA.

Rationale: To deny unauthorized access to the system and any sensitive areas.

Priority: High

Related Standards: OWASP A07:2021 – Identification and Authentication

Failures

- Session Timeout Policy:

Description: User sessions should be terminated automatically after 15 minutes of inactivity to reduce the hazards of session hijacking.

Rationale: To prevent unauthorized access if he/she leaves the session unattended.

Priority: High

Related Standards: OWASP Session Management, ISO/IEC 27001 A.9.4.2

4.3 Data Protection:

- Encryption of Data:

Description: Exposure of data must have sensitive data encrypted in rest in transit by using strong algorithms like AES-256 and TLS 1.3.

Rationale: Protect data from tampering or theft.

Priority: High

Related Standards: OWASP A02:2021 – Cryptographic Failures

- Attendance Log Integrity:

Description: Attendance logs received from external fingerprint scanners must be validated and guarded against tampering.

Rationale: To ensure that attendance records are reliable and that they are not altered without proper authorization.

Priority: High

Related standards: ISO 27001 A.10.1, OWASP Logging Cheat Sheet

4.4 Monitoring and Logging:

- Activity Logging:

Description: The system must log all major user activities with timestamps (logins, changes, deletions).

Rationale: For detection and investigation of any security incidents.

Priority: Medium

Related standards: NIST SP 800-92, OWASP A09:2021 – Security Logging and Monitoring Failures

- Alerting Suspicious Behaviors:

Description: Suspicious access patterns (for example, multiple failed login attempts) must be directed as alerts to the security team.

Rationale: Quick response may intercept a breach.

Priority: Medium

Related Standards: MITRE ATT&CK, OWASP

4.5 Input and Error Handling:

- Input Validation:

Description: All inputs must undergo validation both at the client and server ends to prevent injection attacks.

Rationale: Prevent an attack such as SQL injection and XSS.

Priority: High

Related Standards: OWASP A03:2021 – Injection

- Secure Error Handling:

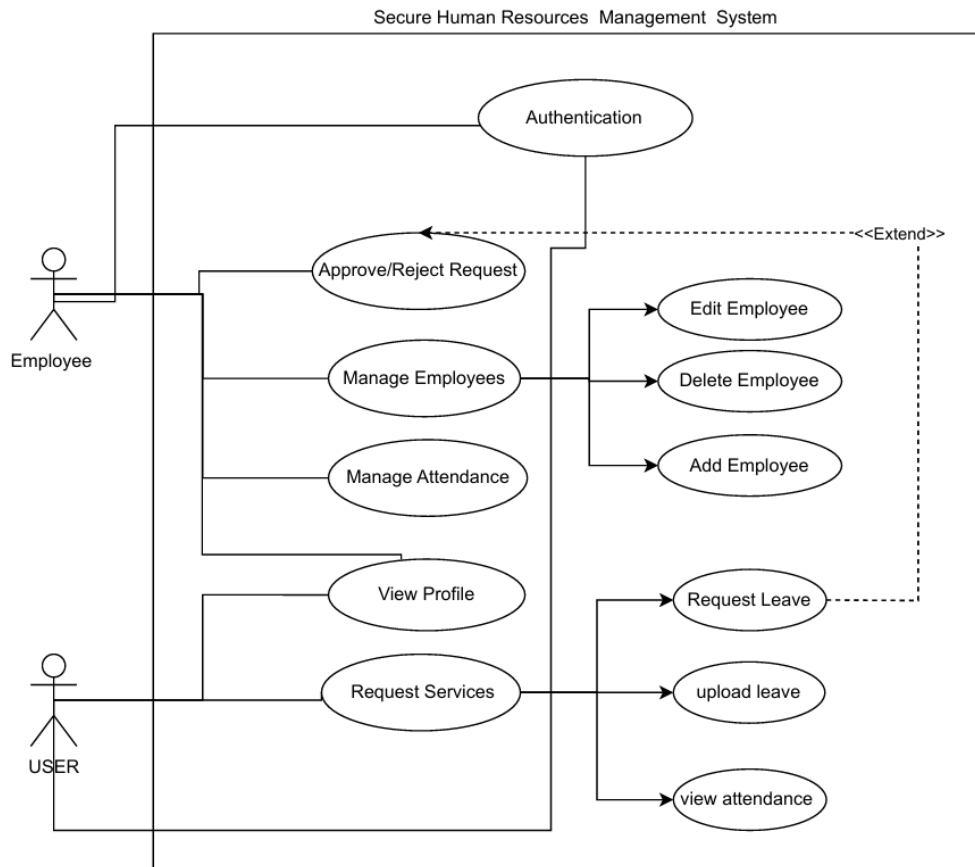
Description: The system should never expose stack traces or other sensitive internal details in error messages.

Rationale: This would allow attackers to collect information about a system.

Priority: Medium

Related Standards: OWASP A01:2021 – Broken Access Control

5.0 Use Case Diagram



6.0 Threat Modelling Threat Modelling

6.1 Identifying Assets:

Employee Data: Includes personal information (names, salaries, attendance records, medical info) and employee profiles.

Authentication Credentials: Passwords, session tokens, and multi-factor authentication (MFA) tokens used to verify users.

Backup Data: Copies of critical system data stored for disaster recovery.

System and Application Code: The source code and business logic of the SafeHR platform.

Logging and Monitoring Data: Logs of user activities, login attempts, leave requests, and system events for auditing and security monitoring.

External Biometric Data: Attendance data collected from fingerprint scanners or other biometric devices.

6.2 Identifying Threats

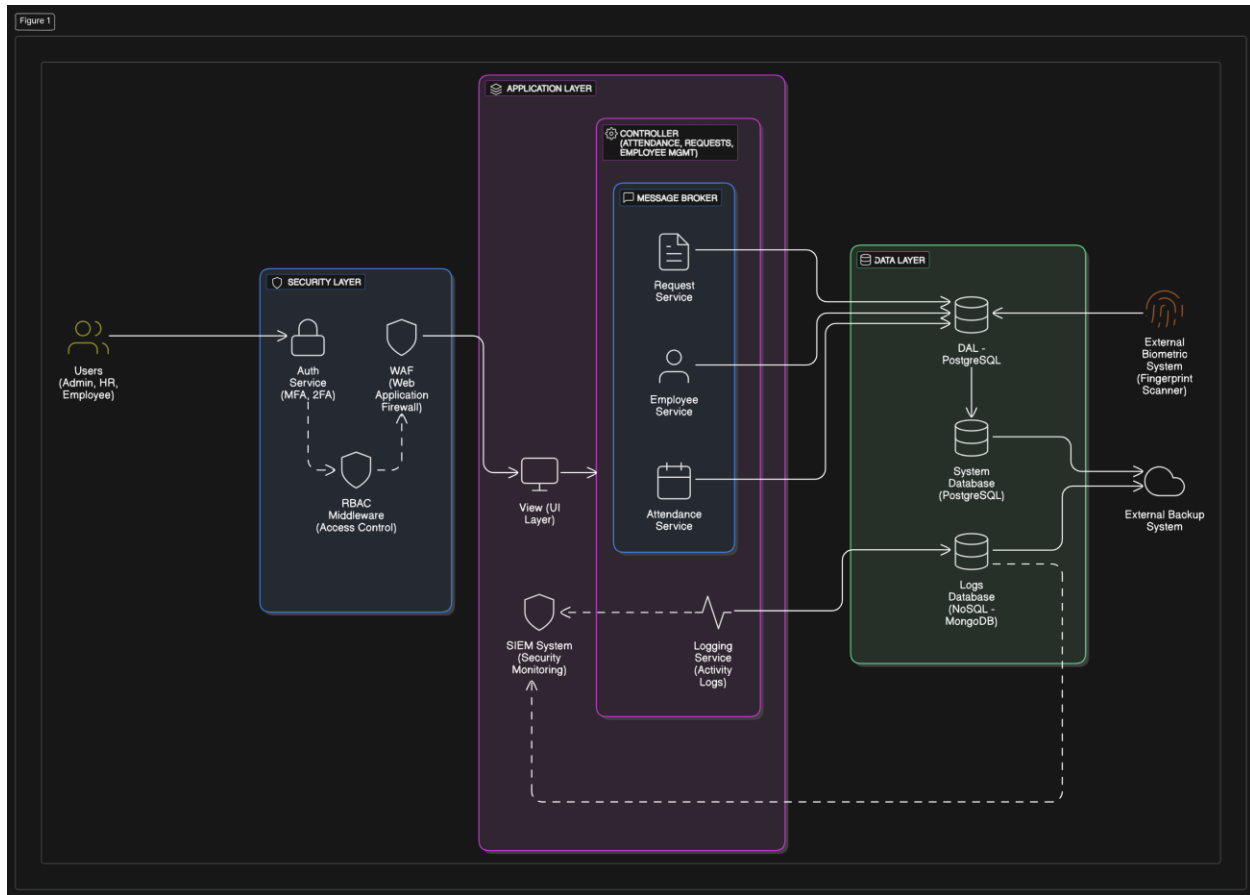
No.	Threat Category	Threat Name	Affected Components	Priority	Suggested Mitigation
1	Elevation of Privilege	Privilege Escalation via Impersonation	RBAC, Authenticator, Login	High	Strict JWT validation, mTLS, audit privilege logs
2	Tampering	Cross Site Scripting (XSS)	Web Servers (RBAC, Attendance, Requests, Employee)	High	Input sanitization, Content Security Policy (CSP)
3	Spoofing	Spoofing Attacks	WAF, Login, Backup, Restore, API	High	Mutual TLS, digital certificates, API gateway verification
4	Denial of Service	Denial of Service (DoS) Attacks	Network, System, Backup, Restore	High	Rate limiting, IDS/IPS, resource monitoring

5	Tampering	SQL Injection	API, Database, Logs, Backup	High	Use ORM, prepared statements, input validation
6	Information Disclosure	Weak Access Control / Data Sniffing	System, Network, Logs, Backup	High	Strong access control, encrypt data at rest and in transit
7	Repudiation	Lack of Audit Logs	Backup, Restore, Logs	High	Enable tamper-proof, detailed audit logging
8	Remote Code Execution	Remote Code Execution (RCE)	Server, Authenticator, Backup, Restore	High	Avoid eval, sandbox critical components
9	Tampering	Malware Upload via File Upload	File Upload	High	Restrict file types, malware scanning
10	Session Management	Insufficient Session Timeout Controls	Session Management	Medium	Enforce session timeouts, monitor sessions
11	Brute Force	Brute Force on Authentication	Authentication	Medium	MFA, account lockout after failed attempts
12	Tampering	Cross-Site Request Forgery (CSRF)	Web Application	High	CSRF tokens, SameSite cookies
13	Misconfiguration	Security Misconfiguration	Servers, Network	High	Harden configuration, disable debug modes

14	Supply Chain Attack	Malicious Dependency Injection	Third-party Libraries	High	Use vetted libraries, dependency scanning
15	Privacy Threats	Exposure of Sensitive Personal Data	Database, Logs	High	Data encryption, strict access control
16	Tampering	Log Corruption	Logs	High	Append-only logs, encrypt logs
17	Spoofing	Spoofing Message Broker	Message Broker	High	Authentication, message signing
18	Tampering	Replay Attacks	Network	High	Nonces, timestamp validation
19	Authentication	Man-in-the-Middle Attacks on SSO	Single Sign-On (SSO)	High	Use PKCE, HTTPS, secure cookies
20	Tampering	Error Message Information Leakage	Application	Medium	Generic error messages, hide stack traces

Although there are several other security threats that could affect the SafeHR system, this report lays focus on the threats identified in the face of time constraints, with the possibility of adding further threats later, should the need arise.

7.0 Architecture Design



- **Users (Admin, HR, Employee)**
people who are going to use the system through the user interface. Each has different permissions based on their role.
- **Security Layer (Auth Service, RBAC, WAF)**
This layer authenticates a user's identity, determines access rights by checking authorization, and protects the system from attacks such as SQL injection or XSS.
- **View (UI Layer)**
The interface that users use to interact with will display data and take inputs from the users.

- Controller

The Controller receives a request from the UI and determines how to handle it. It acts as the nexus between the UI and backend services, also handles the logging of user actions.

- Message Broker

The message broker facilitates communication between services so that they work asynchronously, enhancing solid performance and stability.

Microservices (Employee, Attendance, Request Services)

Services that exist independently and handle specific areas within the system, such as employee management, attendance tracking, and leave request processing.

- Data Access Layer (DAL)

DAL acts like a go-between for the microservices and the databases. It allows the services to read and write data without worrying about the database's operation. It also enforces access control and serves as an extension to ease maintenance on the system.

- Databases

It stores all the data of the system. PostgreSQL stores structured data of employees, attendance, and requests, while MongoDB stores logs and audit trails. An external backup system secures data copies to prevent loss.

- External Biometric System

A fingerprint scanner system that sends attendance data to the attendance microservice.

- SIEM System

The SIEM is designed for collecting and analyzing logs and security events in real-time from various system parts, allowing for suspicious activities to be detected, generating alerts for possible security incidents, and aiding forensic investigations to improve the system's security monitoring and reaction.

8.0 Secure Architecture Design

SafeHR platform is built through a three-tier architecture composed of the front end, backend, and database. Each layer protected with specific security mechanisms adapted to their role.

- Front-end
 - Responsible for handling user interface such as user and employee interactions, form handling, and real-time feedback.
 - All communication is protected via HTTPS with TLS encryption during transmission.
 - Input validation is performed on the client side to defend against injection and irregular data.
- Back-end
 - Manages business logic, secure authentication, QR-based 2FA, and role-based workflows.
 - Logs sensitive operations using secure, non-PII-logging frameworks.
 - Enforces server-side validation, CSRF protection, and RBAC (Role-Based Access Control), with the following reasons:
 - Server-side validation: preventing against injection attacks.
 - CSRF protection: preventing fake requests making sure actions come from a real user.
 - RBAC: restricting access based on user roles.
- Database
 - storing all employee information and system data by using PostgreSQL.
 - Sensitive employee data encrypted at rest by using AES-256.
 - Enforces row-level access control, ensuring that users will access only data depending on their roles.

- Passwords and sensitive credentials are hashed with bcrypt before storage.

Security Principle	Applied
Least Privilege	• Employees only access their own records. • HR can access team data. • Admins have full control. • Backend uses scoped DB roles with limited access.
Defense in Depth	• Input validation on client + server. • WAF to block malicious HTTP traffic. • MFA + hashed passwords + session controls. • CSRF protection.
Fail Securely	• When user authentication fails or 2FA is incomplete, access is denied. • The session expires after 15 mins of inactivity. • Errors return generic messages.
Secure by Default	• New users have minimal permission. • Secure cookies and HTTPS are default.
Minimized Attack Surface	• No debug endpoints in production. • API routes restricted by RBAC. • Unused services/components are disabled. • Metadata is hidden from responses.

9.0 Security Control Design

We enhanced the Secure-by-Design concept by controlling every critical component of SafeHR with layered security according to each control's agreement with a particular threat mitigation needed to mitigate the risks that were specifically identified.

Area	Implementation	Linked Threats	Enhancement
------	----------------	----------------	-------------

			Strategies
Input Validation	HTML5 client-side checks combined with express-validator server-side validation	Tampering, Injection	- Implement regex patterns for strict input formatting - Add multi-layer validation with schema validation - Implement context-specific sanitization
Authentication	Custom-made system using bcrypt for secure password hashing	Spoofing	- Implement adaptive authentication - Add IP-based and geolocation tracking- Implement progressive security challenges
Two Factor Authentication (2FA)	Speakeasy integrated with Microsoft Authenticator (TOTP standard)	Spoofing, Elevation of Privilege	- Support multiple 2FA methods (authenticator app, SMS, hardware tokens) - Implement backup code generation - Add device management and verification
Authorization	Role-Based Access Control (RBAC) applied through middleware	Elevation of Privilege, Information Disclosure	- Create granular permission levels- Real-time access right modifications
Error Handling	Generic messages like 'Invalid credentials'	Information Disclosure	- Implement advanced error logging without exposing system details

			- Create custom errors tracking mechanism - Anonymize error logs
Logging	Structured JSON logs with timestamps and IP addresses (no PII)	Repudiation, Monitoring Failures	- Implement centralized log management - Add real-time security event monitoring - Create automated alert systems
CSRF Protection	Csrf middleware with token-based CSRF validation	Tampering, Forgery	- Implement SameSite cookie attributes - Add additional header-based protections - Dynamic token generation
File Upload Security	Secure file upload process with renaming, type/size restrictions, and malware scanning	Tampering, Information Disclosure	- Implement advanced file type validation - Use multiple antivirus/malwares scanning engines - Limit upload sizes and frequencies
Session Management	Secure JWTs with Secure/HttpOnly cookies, refresh tokens, 15-minute expiration	Elevation of Privilege, Session Hijacking	- Implement token rotation mechanism - Add device fingerprinting - Create comprehensive session audit trails

9.1 RBAC (Role-Based Access Control)

ACTION	ADMIN	HR	EMPLOYEE
Authentication	Allowed	Allowed	Allowed
Edit employee	Allowed	Allowed	Not Allowed
Create new employee	Allowed	Allowed	Not Allowed
Delete employee	Allowed	Not Allowed	Not Allowed
add leaves	Not Allowed	Not Allowed	Allowed
Upload reports	Not Allowed	Not Allowed	Allowed
Vacation request	Not Allowed	Not Allowed	Allowed
Show vacation requests	Allowed	Allowed	Not Allowed
Show requests	Allowed	Allowed	Not Allowed
Show leaves	Allowed	Allowed	Not Allowed
Data center access	Allowed	Not Allowed	Not Allowed
Backup	Allowed	Not Allowed	Not Allowed
Manage attendance	Allowed	Allowed	Not Allowed

10.0 Authentication and QR Code 2FA

A secure internal authentication system is used by SafeHR to protect user identities and reduce the possibility of unauthorized access. The system uses multiple security layers, including **password hashing with built-in salting**, and Microsoft Authenticator-based QR Two-Factor Authentication (2FA).

1. The user inputs their username and password.
2. The bcrypt algorithm is used to compare the password with a securely stored hash.

Bcrypt automatically generates and uses a unique salt per password, enhancing protection against rainbow table attacks.

3. If 2FA is enabled, the system uses the **Speakeasy** library to generate a TOTP (Time-Based One-Time Password) secret.
4. The **qrcode** package transforms the secret into a QR code, which is displayed to the user.
5. The Microsoft Authenticator mobile app generates 30-second TOTP codes when the QR code is scanned.
6. The user enters the current TOTP code, which the backend verifies.
7. Upon successful verification, the user receives a **short-lived JWT (15 minutes)** stored in a **Secure, HttpOnly cookie**. A **refresh token** is also issued for secure session renewal.

Security Benefits

- Strong defense against credential theft
- Salting eliminates risk from precomputed attacks (e.g., rainbow tables)
- No reliance on third-party OAuth providers
- Dynamic TOTP codes improve login security
- Compliant with **NIST, ISO/IEC 27001**, and enterprise security best practices

11.0 Evaluation of Architecture

From the security angle, all three tiers of the system - frontend, backend, and database - the SafeHR architecture was analyzed. Here are the compiled observed strengths and weaknesses.

11.1 Strengths

1. Multifactor Authentication (MFA) Supported

The proprietary authentication system and password storage with bcrypt hash functions increase user verify identity with secure or Two-factor authentication through Microsoft authenticator.

2. Fine-Grained Role-Based Access Control (RBAC)

Allows users as per their assigned roles permissions. Admins, HR executives and employees have separate restricted privileges.

3. Session Management Security

Utilizes short-lived JWT tokens alongside refresh tokens, employing both Secure and HttpOnly cookies to mitigate session hijacking risks.

4. Encrypted Communication and Storage of Data

All sensitive information during transmission is protected using HTTPS protocols with HSTS headers. Data stored at rest is fully encrypted using AES-256 encryption in PostgreSQL.

5. File Upload Protection

Uploaded files are virus-checked, renamed to masks to prevent predictable trajectories like password protected documents, and other document types after being restricted to specified proportions.

6. Cleans Three Tier Architecture

PostgreSQL (Database) separation enhances modularity of the system and improves security policy application per layer.

7. Minimal Attack Surface

In the production environment, all possible information leakage channels are closed, meaning that every debug route, test endpoint, and stack trace are turned off.

8. Trusted and Maintainable Codebase

The use of helmet and speakeasy along with express validator optimizes the project through security features provided by the community and their swift implementation.

9. Secure-by-Design Implementation

The whole system has a Secure-by-Design posture, assuring integration of security at all levels of the SDLC.

11.2 Weaknesses

1. Initial User Training for 2FA Setup

Microsoft Authenticator configuration could be a challenge for some users, especially those who have never used mobile authentication apps.

2. DevOps & Deployment Complexity

Secure deployment introduces an additional layer of operational burden in the governance of environment variables such as TLS certificates, secret keys, and other sensitive information which increases the likelihood of misconfiguration.

3. Lack of Integrated Log Analysis Tools

Security logs are maintained in a structured JSON format which hampers quick review or analysis of logs during incident response.

4. External Dependency for File Scanning

Third-party systems are required to validate the absence of malicious software on files before the organization can use the files.

12.0 Documentation and Justification

12.1 Secure-by-Design Strategy

Secure-by-Design Method SafeHR adhered to a Secure-by-Design development life cycle.

Security considerations were taken at every stage of the project, for example, during system construction like citing data encryption, access control, and authentication as well as choices made within the system's architecture.

Procedures for secure coding and threat modeling were introduced from the Very beginning.

Input validation on the client and server side is implemented to prevent injection attacks.

12.2 Security Requirements

Security Standards Users are restricted, under RBAC access control, to viewing only information that falls within their area of employment. 2FA and multi-factor authentication receive an enhancement from QR codes. For session management, short expiry JWT tokens alongside auto logout are utilized.

12.3 Threat Modeling

The threat Mapping STRIDE technique was applied to do the threats mapping. Some of the major identified threats include Spoofing (including login spoofing), tampering (such malware upload), Privilege Escalation (through impersonation), SQL Injection and denial of service. Each aligned mitigation has been guided by NIST and OWASP.

12.4 Layers of Architecture

- Frontend: Performs input validation and TLS encryption.
- Backend: Contains RBAC logic, CSRF protection, 2FA, authentication, and secure password hashing accomplished using bcrypt with automatic salting. QR-based two-factor authentication is accomplished using Microsoft Authenticator and Speakeasy. A server validates a time-based OTP each time a user logs in. Tokens are stored in HttpOnly and secure cookies.

12.5 Matrix-based RBAC

Permission enforcement applies to three roles: admin, human resources, and employee. For example, only staff can ask for leave; only managers and human resources can handle employee records.

RBAC is implemented using server-side middleware; the database is for validation.

12.6 Matrix of Security Controls

- Among the security protocols are:
- Validation of CSRF tokens
- Tokens for JWT sessions
- Safe file upload

12.7 Monitoring & Logging

Everything that users do is logged with timestamps and IPs in JSON format. Malicious activity (i.e., login failures) is reported and notifications to admins. Audit trails are forensically analyzable. Logs are tamper-evident and monitored in real-time using SIEM.

12.8 Evaluation & Weaknesses

Strengths:

- Secure control of sessions
- 2FA via QR-code
- High-granularity RBAC

- Encryption of communications and storage
- Logs are tamper-evident and observed in real-time with SIEM, enabling centralized correlation, anomaly detection, and automated alerts.

Weaknesses:

- Convenience of 2FA configuration may prove difficult for initial users
- DevOps overhead of having to handle secure deployment parameters

12.9 Compliance & Rationale

Each security control meets international requirements:

- OWASP Top 10: A01 (Access Control), A02 (Cryptographic Failures), A03 (Injection), A07 (Authentication Failures)
- ISO/IEC 27001: A.9 (Access Control), A.10 (Encryption), A.12 (Logging)
- NIST SP 800-53: AC-5 (RBAC), AU-2 (Audit Logs), IA-2 (MFA)

This ensures SafeHR is confidential, cohesive, and accessible in accordance with secure system design.

13.0 Conclusion

In conclusion, SafeHR represents an exemplary realization of a secure-by-design approach to protecting human resource management systems. Given layered security controls such as RBAC, MFA using QR codes, data encryption, input validation, and logging and monitoring, SafeHR addresses key security issues pertinent to privilege escalation, injection attacks, spoofing, and denial of service.

Architecture mainly considers the confidentiality, integrity, and availability of sensitive employee records while balancing usability and scalability for small- and medium-sized enterprises. Challenges abound, such as 2FA training during the initial phase and complex operations in secure deployment; nevertheless, the system's underlying strengths serve as a great winner for defending HR assets legitimately through modern cyber threats.

By applying leading security standards such as OWASP Top 10, ISO/IEC 27001, and NIST guidelines ensures security controls have veracity, are auditable, and compliant. This gave credence to proactive threat modeling and yielding mitigation throughout all phases of the software development lifecycle to produce HR platforms resilient and trustworthy for an ever more digital set-up of modern workplaces.

14.0 References

1. bcrypt. (2023). *bcrypt password hashing for Node.js*. GitHub. Retrieved from <https://github.com/kelektiv/node.bcrypt.js>
2. Khairnar, S. D. (2013). *Human Resource Information System: Important Element of Current Scenario*. IOSR Journal of Business and Management, 13(6), 41–46. Retrieved from <https://www.iosrjournals.org/iosr-jbm/papers/Vol13-issue6/G01364146.pdf?id=7380>
3. Majmaah University. (2018). *Human Resource Management System*. Retrieved from <https://m.mu.edu.sa/sites/default/files/content/2018/12/Human%20Resource%20Management%20System.pdf>
4. Microsoft. (2023). *Microsoft Authenticator App – Two-step verification*. Retrieved from <https://support.microsoft.com/en-us/account-billing/how-to-use-the-microsoft-authenticator-app-9783c865-0308-42fb-a519-8cf70b3a9f0a>
5. National Institute of Standards and Technology (NIST). (2024). *NIST SP 800-53 Revision 5: Security and Privacy Controls for Information Systems and Organizations*. Retrieved from <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>
6. OWASP Foundation. (2024). *OWASP Cheat Sheet Series: Logging and Monitoring*. Retrieved from https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html
7. Tariq, O. (2020). *Design and Implementation of Human Resource Information Systems Based on UML*. Retrieved from

https://www.researchgate.net/publication/341945176_Design_and_Implementation_of_Human_Resource_Information_Systems_Based_on_UML